BEZPIECZEŃSTWO APLIKACJI I SYSTEMÓW MOBILNYCH

Zajęcia 3

Uprawnienia i model bezpieczeństwa platform

Dostęp do danych użytkownika — niezależnie od stacku

Mateusz Kawulok · rok akademicki 2026/27

WSPÓLNY MODEL

Cykl życia uprawnienia — taki sam w każdym stacku

1

Deklaracja

W konfiguracji aplikacji, z opisem celu

2

Prośba

W chwili użycia funkcji, nie przy starcie

3

Decyzja

Zgoda, zgoda ograniczona albo odmowa

4

Użycie

Tylko w zakresie, o który prosiliśmy

5

Cofnięcie

Użytkownik lub system odbiera dostęp

Odmowa to normalny stan

Aplikacja musi działać dalej — bez pętli próśb i bez blokowania całego ekranu.

Zgoda bywa częściowa

Przybliżona lokalizacja, wybrane zdjęcia, wybrane kontakty, tylko „podczas używania”.

Zgoda wygasa

Android cofa uprawnienia nieużywanym aplikacjom; iOS pyta ponownie o lokalizację w tle.

CO CHRONIĄ UPRAWNIENIA

Zasoby, wariant ograniczony i nowości

Zasób	Android	iOS	Wariant ograniczony
Lokalizacja	FINE / COARSE, osobno w tle	Podczas używania / zawsze	Przybliżona lokalizacja
Zdjęcia	READ_MEDIA_IMAGES	Biblioteka zdjęć	Wybrane zdjęcia lub picker
Kontakty	READ_CONTACTS	Kontakty	Wybrane kontakty (iOS 18+)
Aparat, mikrofon	CAMERA, RECORD_AUDIO	Aparat, mikrofon	Wskaźnik użycia w systemie
Sieć lokalna	ACCESS_LOCAL_NETWORK (17)	Sieć lokalna (iOS 14+)	Systemowy picker urządzeń
Bluetooth	BLUETOOTH_SCAN / CONNECT	Bluetooth	Parowanie przez system
Powiadomienia	POST_NOTIFICATIONS (13+)	Powiadomienia	Powiadomienia tymczasowe
Śledzenie	Identyfikator reklamowy	App Tracking Transparency	—

TREND OSTATNICH LAT

System pośredniczy — aplikacja nie potrzebuje uprawnienia

Zdjęcia i wideo

Android Photo Picker, iOS PHPickerViewController / PhotosPicker — użytkownik wybiera pliki, aplikacja nie widzi galerii.

Pliki

Storage Access Framework, UIDocumentPicker — dostęp tylko do wskazanego pliku.

Kontakty

Contact access picker (iOS 18+) — dostęp do wybranych osób zamiast całej książki.

Urządzenia w sieci i BLE

Systemowe pickery urządzeń (Android 17, AccessorySetupKit na iOS) — bez szerokiego skanowania.

DEKLARACJA

Gdzie deklarujemy uprawnienia w każdym stacku

Sekcja	Android	iOS
Android / iOS natywnie	AndroidManifest.xml	Target → Info / build settings
Flutter	android/app/src/main/ AndroidManifest.xml	ios/Runner/Info.plist
React Native (CLI)	android/app/src/main/ AndroidManifest.xml	ios/<App>/Info.plist
Expo	app.json → android.permissions	app.json → ios.infoPlist
Kotlin Multiplatform	androidMain / androidApp manifest	iosApp — projekt Xcode

ZASADA Liczy się to, co trafia do **zbudowanej** aplikacji: scalony manifest i Info.plist w paczce .app — a nie tylko plik w repozytorium.

iOS DZIŚ

Gdzie podziało się Info.plist?

Nowy projekt Xcode

Od Xcode 13 nie ma osobnego pliku. Klucze edytujecie w celu (target) w zakładce Info lub w build settings — Xcode generuje Info.plist przy budowaniu.

Gotowa aplikacja

Info.plist nadal jest w paczce .app — to ten plik czyta system i audytor.

Privacy manifest

PrivacyInfo.xcprivacy: zbierane dane i powody użycia wybranych API. Wymagany od maja 2024, także od popularnych SDK.

```
// build settings nowego projektu
GENERATE_INFOPLIST_FILE = YES
INFOPLIST_KEY_NSCameraUsageDescription =
  "Skan biletu przy wejściu"

// w zbudowanej aplikacji
plutil -p MyApp.app/Info.plist

// Flutter, RN — plik w repozytorium
ios/Runner/Info.plist
```

UPRAWNIENIA, KTÓRYCH NIE DODALIŚCIE

Biblioteki dopisują swoje — sprawdźcie i usuńcie zbędne

```
ANDROID · USUNIĘCIE Z MANIFESTU BIBLIOTEKI
<uses-permission
  android:name=
    "android.permission.READ_PHONE_STATE"
  tools:node="remove" />

FLUTTER · permission_handler NA iOS
# Podfile — kompilujemy tylko potrzebne
'PERMISSION_CAMERA=1',
'PERMISSION_LOCATION=0',
```

Gdzie patrzeć

Android Studio → Merged Manifest; na iOS Info.plist i PrivacyInfo.xcprivacy w zbudowanej aplikacji.

Typowi winowajcy

SDK reklamowe i analityczne, wtyczki map i geolokalizacji, biblioteki do zdjęć.

PROŚBA W KODZIE

Ten sam wzorzec w każdym stacku

```
FLUTTER · permission_handler
Future<void> scanTicket() async {
  final s = await Permission.camera.request();
  if (s.isGranted) return openScanner();
  if (s.isPermanentlyDenied) {
    return showSettingsHint();
  }
  showManualCodeEntry();
}
```

Stany, które trzeba obsłużyć

`granted / limited`
pełny lub częściowy dostęp

`denied`
można zapytać ponownie

`permanentlyDenied`
tylko przez ustawienia systemu

`restricted`
zablokowane, np. kontrolą rodzicielską

WARSTWY OCHRONY

Tło: warstwy ochrony Androida i iOS

Warstwa	Android	iOS
Dystrybucja	Google Play, Play Protect; instalacja spoza sklepu możliwa	App Store Review; w UE także alternatywne sklepy
Podpis aplikacji	APK Signature Scheme, Play App Signing	Certyfikat Apple, profil provisioningowy
Uprawnienia	AndroidManifest, uprawnienia w czasie działania	Klucze Info (generowane Info.plist), entitlements
Komunikacja między aplikacjami	Intenty, content providery, Binder	Schemy URL, universal links, rozszerzenia
Izolacja (sandbox)	Osobny użytkownik Linux + SELinux	Sandbox i kontener aplikacji
Szyfrowanie danych	File-Based Encryption	Data Protection — klasy ochrony plików
Sprzęt i rozruch	Verified Boot, TEE, StrongBox	Secure Boot, Secure Enclave

PRZYKŁAD

Android: ten sam manifest — dwa razy

✗ ŹLE

```
<application
  android:allowBackup="true"
  android:debuggable="true"
  android:usesCleartextTraffic="true">
  <activity
    android:name=".AdminActivity"
    android:exported="true" />
```

✓ DOBRZE

```
<application
  android:allowBackup="false"
  android:dataExtractionRules="@xml/rules"
  android:networkSecurityConfig="@xml/nsc">
  <activity
    android:name=".AdminActivity"
    android:exported="false" />
```

ATAK

Eksportowana aktywność omija logowanie

1 · ATAKUJĄCY	2 · INTENT	3 · CEL	4 · SKUTEK
Inna aplikacja lub adb na urządzeniu	Bezpośrednie uruchomienie wybranej aktywności	AdminActivity z exported=true i bez sprawdzenia sesji	Ekran administratora bez logowania

```
# uruchomienie aktywności z pominięciem ekranu logowania
adb shell am start -n pl.przyklad.app/.AdminActivity
```

Obrona: exported=false wszędzie, gdzie to możliwe, i sprawdzanie sesji w każdym ekranie — nie tylko na starcie.

ARKUSZ SEKCJI · 10 MIN

Na zajęciach

- ✓ Wypiszcie każde uprawnienie: po co, kiedy prosicie, co przy odmowie
- ✓ Sprawdźcie, co trafia do zbudowanej aplikacji — także od bibliotek
- ✓ Które uprawnienie da się zastąpić pickerem albo wariantem ograniczonym?
- ✓ Przetestujcie odmowę jednego uprawnienia (pm revoke / simctl privacy)

NA ZAJĘCIA 4

Zadanie na następny tydzień

- ✓ Tabela uprawnień: po co, kiedy prosimy, co przy odmowie
- ✓ Usunięte zbędne uprawnienia — także te dodane przez biblioteki
- ✓ Test odmowy każdego uprawnienia
- ✓ Lista danych przechowywanych lokalnie na urządzeniu